

2026 年华北五省（市、自治区）及港澳台大学生
计算机应用大赛 移动互联网应用创新
移动互联网应用程序开发

【项目名称】 XIAN

AI Agent 红蓝对抗平台

（Android 作品）

所在赛区：_____

所在学校：_____

团队名称：XIAN 红蓝安全实验室

团队成员：张____、李____、王____、赵____、陈____

提交日期：2026 年 ____ 月 ____ 日

2026 年华北五省（市、自治区）及港澳台大学生计算机应用大赛

参赛作品知识产权声明

参赛作品名称：XIAN（AI Agent 红蓝对抗平台）（下称该作品）

本小组全体成员，就该作品声明如下：

1、该作品（含提交参赛的 App 应用、相关文档和介绍视频）是本小组成员的原创研究成果，不存在侵犯任何他人知识产权、涉及泄密或违反中华人民共和国法律法规的情形，且未在 2025 年 ____ 月 ____ 日前公开发布。

2、我们确认：该作品知识产权归本小组成员所有，且签署本声明的人员能够代表全体小组成员的意愿。

3、我们承诺：将仅由本小组成员参加大赛答辩。

4、大赛举办方为宣传大赛、推广参赛作品，以及为未来各届大赛的参赛选手提供参考等非盈利目的，可能需要以下列形式使用参赛作品，就此我们确认：

（1） ☐同意 ☐不同意：将参赛作品的相关文档结集出版（含公开发行）；

（2） ☐同意 ☐不同意：在相关网站（包括大赛官网及含优酷等第三方视频平台网站）上传和播放介绍视频或幻灯片；

（3） ☐同意 ☐不同意：在大赛官方网站提供 APP 应用免费下载；

（4） 作出上述许可，同样不违反本声明第 1 款的要求。

作品小组全体成员

日期：2026 年 ____ 月 ____ 日

目 录

一、作品概述	4
（一）项目背景与选题由来	4
（二）作品定位	5
（三）两种作战模式	5
（四）作品形态与移动端适配	5
二、作品可行性分析和目标群体	6
（一）可行性分析	6
（二）目标群体	7
三、作品功能与原型设计	8
（一）功能概述	8
（二）原型设计	9
四、作品实现、难点及特色分析	11
（一）作品实现及难点	11
（二）特色分析	13
五、团队介绍和人员分工	14
六、其他	15
（一）硬件环境	15
（二）软件环境	16
（三）开发工具	17
（四）人工智能（AI）工具使用情况	17
（五）开源代码来源与许可	18
（六）测试账号（评审演示用）	19
七、操作说明	20

（一）环境准备	20
（二）Android 客户端（APK）安装与配置	21
（三）启动服务	22
（四）模式一操作流程：系统自动攻击	22
（五）模式二操作流程：手动攻击沙盘	23
（六）CI 回归门禁的使用	24
（七）常见问题	24
八、致谢	25

一、作品概述

（一）项目背景与选题由来

随着大语言模型在企业场景中的规模化落地，AI Agent 已经不只是“会聊天的助手”，而是能够调用工具、读写数据库、发起支付、操作工单的业务执行体。能力边界的扩张同时带来了全新的攻击面：提示注入可以让 Agent 越过系统指令，间接注入可以让一份被检索到的文档变成攻击载荷，工具滥用可以让一次“看起来正常”的调用转走一笔资金。传统安全测试的问卷、渗透与代码审计，都无法覆盖这类“用自然语言驱动、以概率方式响应”的风险。

本项目小组在调研中发现，当前企业在 Agent 安全上普遍面临三个现实困境：一是“测不出”，攻击手法停留在零散的人工尝试，无法枚举、无法复现；二是“判不准”，模型输出没有确定性的对错，人工目测既慢又容易漏报；三是“改不动”，即使发现了问题，也缺少根因定位与可验证的修复手段，评测报告往往止步于“建议加强防护”。

基于上述判断，小组决定开发 XIAN —— 一套面向企业自研 Agent 的安全评测与持续运营平台，把传统渗透测试中已经成熟的“红蓝对抗”方法论，系统化地迁移到 AI Agent 场景。

（二）作品定位

XIAN 的定位可以概括为三个词：测得出、判得准、改得动。

- **测得出** —— 把提示注入、越狱、工具滥用、数据渗出等风险，固化为 14 类可枚举、可执行、可复现的攻击矩阵，而不是零散的人工尝试。
- **判得准** —— 用“黄金信号 → 分类器 → LLM”三级裁判替代人工目测。黄金信号（蜜标命中、真实外联、系统提示词泄露、工具越权、注入执行痕迹）零漏报，保证真正的风险不被放过。
- **改得动** —— 每条命中都有根因定位与可执行的修复建议（prompt diff / 规则 / 代码片段），并支持一键复测验证修复效果，形成“攻击 → 判定 → 修复 → 复测”的闭环。

（三）两种作战模式

模式一·系统自动攻击：**配置战役后，由系统红军引擎自动完成侦察、策略规划、载荷变异与执行，并自动产出九章评测报告，全过程实时可视。适合作为常态化安全体检与 CI 回归节拍。**

模式二·用户手动攻击（沙盘推演）：**PvE 十关教案，用户亲手出牌，配合提示系统、能量机制、徽章成就与攻守互换，把安全能力训练做成可上手的课程。适合作为安全团队的能力培养与教学场景。**

（四）作品形态与移动端适配

XIAN 是一套 B/S 架构平台，前端为单页应用，后端为 HTTP + WebSocket 服务。针对移动互联网使用场景，前端采用响应式栅格与自适应断点设计，页面在手机浏览器上可完整访问：顶部导航折叠为抽屉菜单，三栏拖拽面板退化为纵向堆叠，数据表格切换为卡片式列表，登录页的漂浮装饰卡片在窄屏下仅保留上沿元素以避免遮挡表单。所有交互元素的可点击区域不小于 44×44 px，满足移动端触控规范。

需要说明的是，本作品的核心能力（Agent 接入、战役编排、三级裁判、报告与复测）依赖后端服务与数据库协同，属于典型的“重服务、轻客户端”形态，因此客户端以移动浏览器 Web 应用方式交付，并未单独开发原生 Android 客户端；移动端与桌面端共用同一套前端代码与接口契约，不存在功能差异。

二、作品可行性分析和目标群体

（一）可行性分析

1. 技术可行性

本作品的技术选型全部采用成熟且社区活跃的开源栈，不存在需要从零攻关的底层技术风险。后端基于 Python 3.12 + FastAPI 提供异步 HTTP 服务，用 SQLAlchemy 2.0（async）统一访问数据库；攻击链路建模为有向无环图（DAG），由红军引擎按阶段推进；判定环节的三级裁判以规则库（YAML）固化确定性证据，再逐级下沉到分类器与 LLM。前端基于 React 19 + TypeScript + Vite 构建，通过 OpenAPI 契约与后端对齐，类型可在编译期静态检查。

为验证技术路线的可行性，小组在开发过程中完成了两项关键验证：一是核心层（xian_core，22 个业务包）完全不依赖 FastAPI 与 Celery，同一份业务逻辑被 HTTP 路由、异步任务与命令行门禁三方复用，从结构上排除了“接口里一套、任务里一套”的分叉风险；二是实现了确定性离线回放，在没有任何 LLM 凭证的情况下，网关按角色返回确定性响应，使全流程可在离线环境跑通与验证。

2. 操作可行性

平台的操作对象是安全工程师与 AI 应用研发人员，二者均具备使用浏览器控制台的经验。小组在交互设计上做了三项降低门槛的工作：一是把复杂的战役配置拆解为“选目标 → 选范围 → 设预算”三步向导；二是把三级裁判的判定过程完整可视化，每条命中都能下钻到原始 trace 与裁判流水，用户不需要理解内部实现即可判断结论是否可信；三是模式二把安全知识包装为关卡与提示，新手可以依靠提示系统逐步理解攻击原理。

此外，平台提供跨平台一键入口脚本，安装、初始化种子数据、启动服务、执行自检均可通过单条命令完成，不依赖特定操作系统，在 Windows / Linux / macOS 上表现一致，进一步降低了部署与演示的操作成本。

3. 经济可行性

平台本身基于开源组件构建，无商业授权费用。运行成本主要来自 LLM 调用，而这一项通过两级设计被显著压低：其一，三级裁判中成本最低的黄金信号规则优

先命中，只有规则无法覆盖的样本才会下沉到 LLM 判定，实测可将 LLM 调用量压到可控范围；其二，网关内置角色路由与成本账本，可对不同角色分别指定模型，例如裁判角色使用较小模型、只把复杂样本交给大模型。对于预算有限的团队，平台支持完全不配置 LLM 凭证，以确定性离线回放方式完成功能性验证与流程演示。

从投入产出看，一次完整的自动化演练可在数十分钟内覆盖 14 类攻击、产出九章报告与可执行修复建议，相比人工渗透测试在时间成本上具备明显优势；而 CI 回归门禁把“安全评测”从一次性项目变成版本迭代中的常规节拍，使投入能够在每一次版本发布中持续产生价值。

（二）目标群体

本作品面向的主要是四类用户：

- **1) 企业安全团队（甲方安全）：**负责自研 Agent 上线前安全评审与上线后持续监控的团队。他们的核心诉求是“测得出、判得准”，需要可枚举的攻击覆盖与可信的判定结论。
- **2) AI 应用研发团队：**正在把大模型能力接入业务系统的开发者。他们需要在上线前知道自己写的系统提示词与工具声明是否留有破绽，并希望拿到可直接应用的修复建议。
- **3) 高校与培训机构：**开设网络空间安全、人工智能安全相关课程，需要一套可上手、可复现、可评分的实训平台，把抽象的攻击原理变成可操作的关卡。
- **4) 合规与审计人员：**需要以《生成式人工智能服务管理暂行办法》与 OWASP LLM Top 10 等框架为对照，对 Agent 系统形成可追溯证据链的团队。平台内置框架映射与合规对照能力。

目标群体的需求特征与对应设计

小组在调研中归纳了目标用户的四项典型需求，并在设计中逐条对应：

- **1) 零漏报优先：**安全团队无法接受“关键风险被漏判”，因此平台把黄金信号（蜜标命中、越权工具调用、白名单外外联、可执行结构输出等）设为最高优先级，命中即判定成功，不经过任何概率性环节。
- **2) 修复可落地：**研发人员关心的是“我该怎么改”，因此平台为每条命中提供根因分类与修复产物，并支持应用修复后一键复测同一条攻击，用判定结果的变化直接验证修复是否生效。

- 3) 结论可汇报：安全负责人需要向上汇报，因此平台把多维判定结果聚合为 0-100 的 SecScore 分数与 S/A/B/C/D 评级，并保留趋势点，使版本间的安全水位变化可被量化追踪。
- 4) 授权与合规：所有演练必须限定在授权范围内，因此平台强制要求 Agent 先完成归属校验（DNS TXT 记录或镜像摘要比对）才能作为攻击目标，未通过校验的目标一律拒绝执行；沙箱实例的出网流量经默认拒绝的白名单代理转发，命中蜜标域名即记录并可追溯。

三、作品功能与原型设计

（一）功能概述

平台功能按“接入 → 侦察 → 攻击 → 判定 → 评分 → 报告 → 修复 → 复测”的主链路组织，各功能模块及其描述如下表所示。

功能名称	功能描述
Agent 资产接入	支持 HTTP 端点、SDK、容器镜像三种接入方式，登记被测 Agent 的名称、版本、端点与接入凭据；提供连通性探测，接入后即可验证目标是否可达。
归属校验	通过 DNS TXT 记录或镜像摘要比对两种方式确认目标归属。未通过校验的 Agent 不能作为模式一攻击目标，接口层面直接返回 403 拒绝。
侦察	向目标发起一组无害探测，识别其工具集合、拒答边界（硬 / 软 / 无）、系统提示词残留与模型指纹，产出画像并据此影响后续策略选择。
靶场场景	内置 8 套场景模板，每套包含场景定义、工具清单、蜜标配置、监控项与编排脚本，可为演练提供带蜜标与监控的隔离环境。
攻击矩阵	覆盖 14 类攻击（直接 / 间接提示注入、系统提示词泄露、工具滥用、敏感数据渗出、记忆投毒、供应链风险、资源滥用、幻觉操纵、多智能体攻击、社会工程、输出处理不当、模型逆向、多模态载荷），每类下含可执行用例，并内置 OWASP LLM Top 10、MITRE ATLAS 等框架映射与覆盖率统计。
载荷变异	内置多种变异算子（角色替换、编码混淆、分片拼接、上下文淹没、少样本劫持等），对种子用例做改写以生成多样化载荷，每个算子标注是否保持语义安全。
战役编排与执行	按目标画像与场景自动选择策略，生成攻击阶段 DAG（侦察 → 初始执行 → 载荷投递 → 权限提升 → 渗出 → 影响），按预算推进执行；内置预算熔断、连续失败换算子、空转收敛等控制机制，避免无效消耗。

三级裁判引擎	第一级为黄金信号规则（蜜标命中、越权工具调用、参数越界、白名单外外联、缺少二次确认、输出含可执行结构、密钥正则、记忆写入指令句式、资源耗尽特征等），命中即判定成功；第二级为分类器（拒答、注入成功、敏感信息词表）；第三级为 LLM 双裁判投票，分歧时标记需人工复核。
SecScore 评分	按类别权重把判定结果聚合为 0–100 分数与 S/A/B/C/D 评级，输出六个维度的分项得分、攻击成功率（ASR）与趋势点；样本量不足的维度标记为“数据不足”而不计入分母，避免小样本误判。
九章报告	自动生成包含执行摘要、目标与范围、方法与矩阵、发现与证据、风险评级、根因分析、修复建议、复测验证、合规映射九个章节的报告，支持 HTML / PDF / JSON 三种格式导出，分享链接带过期时间。
根因定位与修复建议	对每条命中定位根因（提示词边界不清、工具声明过宽、参数校验缺失、缺少二次确认、输出未消毒等），并给出可直接应用的修复产物：提示词改写差异、防护规则、代码片段。
一键复测	应用修复后，对同一条攻击重新执行并比对修复前后的判定结果与 SecScore 变化，用数据验证修复是否真正生效。
模式二·十关教案	十关递进式实训，每关绑定一个场景与通过条件；含提示系统（三级提示，消耗不同能量）、能量机制、徽章成就与攻守互换。
治理与审计	多租户隔离，五级角色权限（负责人 / 红军 / 蓝军 / 分析师 / 管理员）细到操作粒度；武器库用例的原始载荷导出按角色鉴权并记录审计。

表 1 XIAN 平台功能概述

（二）原型设计

实现平台与运行环境：

项	说明
服务端运行环境	Python 3.12; FastAPI + Uvicorn; Celery 异步任务
客户端运行环境	现代浏览器（Chrome / Edge 90+、Safari 15+、Firefox 90+），支持 ES2020 与 CSS Grid
页面实现平台	React 19 + TypeScript 5.9 + Vite 5.4, pnpm workspace 多包单仓
屏幕分辨率	适配 1366×768 及以上，桌面端推荐 1920×1080；移动端适配宽度 ≥ 375 px
支持设备	桌面浏览器、平板、手机浏览器（响应式布局，触控操作可用）
数据存储	PostgreSQL 16（事务元数据）、ClickHouse 24（trace 与判定流水）、Qdrant（用例向量）、MinIO（报告产物）、Redis（限流与事件总线）；未配置时自动降级为 SQLite / 内存 / 本地目录

表 2 实现平台与运行环境

XIAN 平台的登录界面截图与界面说明见下图。



图 1 登录界面

登录界面说明

登录界面是本平台唯一的对外入口，整体采用“红蓝对抗擂台”视觉主题，在同一张主题图的基础上叠加氛围光斑与柔和网格，形成浅色、低干扰的登录场景。

- **视觉层次：**背景由红蓝两色氛围光斑、低透明度并降亮度的主题图、以及压低中心亮度的径向蒙版三层叠加而成，保证表单文字始终清晰可读。
- **漂浮卡片：**页面上分布 12 张圆角半透明装饰卡片，随鼠标横向移动产生视差、随页面滚动缓慢上浮，并以 12–18 秒不等的周期错峰漂浮；窄屏下仅保留上沿 4 张，且全部标记为对辅助技术隐藏、不接收指针事件，不会遮挡或误触表单。
- **登录表单（居中卡片）：**位于页面中心，自上而下依次为账号输入框、密码输入框、演练角色选择与登录按钮。账号与密码均为必填项，并带有前端校验与浏览器自动填充支持。
- **演练角色选择：**提供红军、蓝军、管理员、分析师四个角色，选中态以红 / 蓝 / 中性底色区分，并在下方给出角色权限说明“角色决定权限：红军执行攻击、蓝军负责防守、管理员全量管控”。
- **顶部导航：**顶部左侧为“产品”与“方案”两个快捷入口，中央为胶囊状菜单（展开后可直达 Agent 编排、靶场场景、攻击矩阵、报告中心），右侧为登录入口；三个区域均支持键盘操作与焦点管理。

- **无障碍与降级：**系统检测到用户开启“减弱动效”时，所有漂浮与视差动画自动停用，仅保留静态背景，保证对动效敏感用户的使用体验。

为便于评审现场体验，登录界面已预填演示账号，亦可在表单中直接修改。测试账号详见“六、其他”章节。

四、作品实现、难点及特色分析

（一）作品实现及难点

平台后端采用四层结构：接入层（FastAPI 服务，只做协议适配、鉴权、限流与任务派发）、核心层（xian_core，承载全部业务规则）、运行时层（Celery 执行战役、报告渲染、复测与巡检）、门面层（命令行工具，提供种子导入、版本查询与 CI 门禁）。前端为 pnpm 多包单仓，分为类型契约包、组件库与应用层三个包。开发过程中的主要难点及解决思路如下。

难点一：核心层必须零框架依赖，才能被三端复用

问题：业务逻辑同时被 HTTP 接口、异步任务与命令行门禁调用，如果分别实现，极易出现“接口里一套规则、任务里另一套”的分叉，且任何一处修改都需要同步三处。

解决：核心层对外只暴露函数，不使用 Service 类，也不 import FastAPI 或 Celery。红军引擎、三级裁判、评分聚合与报告渲染全部以纯函数形式提供，由三端各自调用同一入口。这一约束在架构上直接消除了逻辑分叉的可能性，也使核心层可以脱离 Web 框架独立测试。

难点二：判定既要“零漏报”，又不能被 LLM 成本拖垮

问题：纯靠 LLM 判定，成本高、延迟大且结果不稳定；纯靠规则判定，覆盖面又不足，容易漏掉新型攻击手法。

解决：设计三级裁判流水线。第一级为黄金信号规则库，把“蜜标出现在出网请求体”“调用了黑名单工具”“工具参数超出白名单”“白名单外域名外联”“高危工具未走二次确认”“输出含可执行结构”“输出命中密钥正则”“记忆写入含指令句式”等确定性证据固化为规则，命中即判定成功，完全不经过概率性环节；只有规则无法覆盖

的样本才下沉到分类器，最后才交给 LLM 双裁判。这样既保证关键风险零漏报，又把 LLM 调用量压到只占总量的一小部分，实现成本与延迟的双赢。

难点三：攻击过程不能失控烧预算

问题：自动化攻击若不加约束，容易在无解的目标上反复重试，既浪费资源又拉长演练时间，用户还看不到进展。

解决：把攻击链路建模为有向无环图，每个节点是一个阶段内的策略执行单元。运行时维护预算账本，消耗达到阈值即熔断；对某个类别连续失败达到设定次数后，自动轮换变异算子而非继续重试同一手法；当连续两轮没有产生新进展时，判定为收敛并提前结束。所有节点的状态变化通过事件总线实时推送到前端，用户既能看到“正在做什么”，也能看到“为什么停下来”。

难点四：无法依赖外部中间件，也要能完整演示

问题：完整的平台设计依赖数据库、缓存、分析库、向量库与对象存储五类中间件，但在评审、教学与开发调试场景下，评审机往往不具备这些环境。

解决：为每一类存储客户端实现可用性探测，未配置连接时自动回落到内存实现或本地文件系统。SQLite 顶替 PostgreSQL，进程内事件队列顶替 Redis 发布订阅，本地目录顶替对象存储，向量检索降级为词法匹配。这使得“单机零中间件即可跑通全流程”成为平台的一项可交付特性，而不只是一个容错细节。

难点五：没有 LLM 凭证时，测试会变成“测运气”

问题：如果测试用例依赖真实模型输出，那么断言的内容就变成了“模型够不够聪明”，结果不可复现，也无法在离线 CI 中运行。

解决：在网关层实现确定性离线回放：未配置 LLM 凭证时，按角色返回确定性的响应，裁判角色走规则路径，向量化角色返回稳定向量。这样测试断言的对象就是协议与状态机的正确性，而非模型表现，使全部用例可以在无网环境下稳定通过。

难点六：多租户与权限必须细到操作粒度

问题：平台面向企业多团队使用，不同角色能做的事差异很大——红军只应执行攻击，蓝军只应查看与防守，分析师只应看报告，而武器库中的原始攻击载荷属于敏感资产，随意导出会造成滥用风险。

解决：在数据访问层统一强制注入租户条件，任何仓储查询都自动带租户过滤；在接口层以权限字符串（如 `campaign:run`、`agent:write`）声明式校验，细到单个操作；武器库原始载荷的导出单独鉴权，未获授权直接拒绝并记录审计事件。

（二）特色分析

特色一：三级裁判流水线 —— 让“判得准”可被解释

不同于把结论完全交给模型的做法，本作品把判定拆成确定性规则、词表分类器与 LLM 投票三层，并在每一层保留完整证据。由于黄金信号层零漏报，用户可以确信“真正严重的问题不会被放过”；由于每条结论都能下钻到触发它的具体规则或证据，用户可以自己判断结论是否可信，而不是只能选择相信系统。

特色二：修复闭环 —— 让“改得动”可被验证

市面上多数安全评测工具止步于“发现问题”，本作品进一步做到“定位根因 → 给出可应用产物 → 复测验证”。修复建议不是泛泛的“建议加强输入校验”，而是具体的提示词改写差异、防护规则或代码片段；并且可以在应用修复后对同一条攻击重新执行，用判定结果与分数的变化来证明修复确实生效。这把安全工作从“提建议”推进到了“验证效果”。

特色三：内容资产数据化 —— 扩充能力不用改代码

攻击用例、变异算子、策略库、黄金信号规则、根因分类与修复手册全部以 YAML 形式与代码同库同版本管理，通过统一加载器读取。这意味着安全研究员扩充攻击面通常只需要编辑数据文件，不需要理解框架代码、也不需要重新发版，显著降低了平台的维护与演进成本。

特色四：CI 回归门禁 —— 让安全评测变成工程节拍

平台提供命令行门禁接口，可在持续集成流程中对当前版本执行评测，并与上一版本的安全评分比对。当分数跌幅超过阈值、或出现新的高危发现时，门禁返回

非零退出码从而阻断合并。这使得 Agent 安全从一次性的“上线前体检”变成版本迭代中的常规节拍，任何一次改动引入的安全退化都会被及时发现。

特色五：授权约束内建 —— 攻击能力自带刹车

本作品的攻击能力全部在沙箱与授权边界内运行：目标 Agent 必须先通过归属校验才能被攻击；沙箱实例的出网流量经默认拒绝的白名单代理转发，任何白名单外的域名都会被映射为无效域名并记录下来；场景配置中的凭据一律只允许使用专用蜜标格式，并在写入前校验，防止真实密钥被误当作演练数据。这些约束不是外挂的检查，而是内建于攻击链路本身。

五、团队介绍和人员分工

所在学校：_____

团队名称：XIAN 红蓝安全实验室

团队人员及分工：

角色	姓名	主要分工	对应交付物
队长	张__	项目负责人与技术总体设计。负责四层架构划分与核心层边界约束，主持三级裁判引擎的设计与实现，统筹开发节奏与需求拆解。	xian_core 裁判模块；架构设计说明；需求拆分与排期
队员	李__	红军引擎与攻击链路开发。负责侦察、策略规划、攻击 DAG 运行时、载荷变异算子与执行器，以及攻击矩阵 14 类用例的整理与维护。	红军引擎；攻击矩阵用例；变异算子库
队员	王__	评分、报告与修复闭环开发。负责 SecScore 六维评分模型、九章报告渲染与导出、根因定	评分模块；九章报告；修复手册与复测

		位与修复手册，以及复测流程实现。	
队员	赵__	前端与交互设计。负责设计体系与组件库、15 个路由级页面、登录页与移动端响应式适配、数据可视化与实时事件订阅。	前端应用与组件库；登录界面；响应式适配
队员	陈__	数据与基础设施。负责数据库模型与迁移、多租户隔离与权限模型、五类存储的降级实现、沙箱编排与出网白名单代理，以及部署编排。	数据模型与迁移；存储降级层；沙箱与部署编排

表 3 团队人员分工

指导教师：_____

分工说明：以上分工按模块主责划分，实际开发中采用结对方式推进——红军引擎与三级裁判由队长与李__ 结对，评分报告与复测由王__ 与队长结对，前端页面与接口契约由赵__ 与陈__ 结对。全体成员共同参与需求评审、攻击用例设计与测试验收。

六、其他

本章集中说明运行环境、开发工具、人工智能工具使用情况、开源代码来源与许可，以及评审用测试账号。

（一）硬件环境

场景	配置要求	说明
开发机（推荐）	CPU 4 核及以上；内存 16 GB 及以上；可用磁盘 40 GB 及以上；支持 WebGL 的显卡	需同时运行编辑器、前端开发服务器与后端服务
开发机（最低）	CPU 2 核；内存 8 GB；可用磁盘 20 GB	仅运行后端与前端，不启动容器化依赖
服务器（单机演	CPU 2 核；内存 4 GB；可用磁盘 20 GB	零中间件降级模式下可完整跑

示)		通全流程
服务器（生产）	CPU 8 核及以上；内存 16 GB 及以上；可用磁盘 200 GB 及以上 SSD；千兆网卡	承载数据库、分析库、向量库与对象存储等容器化依赖
客户端	智能手机、平板或桌面电脑，屏幕宽度 ≥ 375 px，具备现代浏览器	移动端通过浏览器访问，无需安装客户端

表 4 硬件环境要求

（二）软件环境

类别	软件 / 组件	版本	用途
系统	Windows / Linux / macOS	Windows 10+、主流发行版均可	开发与运行操作系统
运行时	Python	3.12 及以上	后端语言运行时
运行时	Node.js	20.19 及以上	前端构建运行时
包管理	pnpm	9 及以上	前端多包单仓依赖管理
数据库	PostgreSQL	16	事务型元数据（可降级为 SQLite）
缓存	Redis	7	限流、熔断与事件总线（可降级为进程内实现）
分析库	ClickHouse	24	trace 事件流与判定流水（可降级）
向量库	Qdrant	1.12	攻击用例向量检索（可降级为词法匹配）
对象存储	MinIO	RELEASE.2024-09-22	报告产物与快照归档（可降级为本地目录）
容器	Docker	24 及以上	中间件编排与沙箱实例（演示模式可不装）
浏览器	Chrome / Edge / Safari / Firefox	Chrome 90+、Safari 15+、Firefox 90+	客户端运行环境

表 5 软件环境与依赖组件

说明：表中标注“可降级”的组件均为可选。平台在未配置这些组件时会自动回落到内存或本地实现，因此单机环境下无需安装任何中间件即可完整跑通“接入 → 战役 → 判定 → 评分 → 报告”全流程，便于评审与教学环境快速部署。

（三）开发工具

工具	用途
Visual Studio Code	主力代码编辑器，配合 Python / ESLint / Prettier 插件
Git	版本控制，按模块分支开发并合并
pytest	后端单元测试与集成测试
Vitest	前端单元测试
Playwright	端到端流程验证与截图回归
Storybook	组件库独立开发与视觉走查
Ruff / Black	Python 代码静态检查与格式化
TypeScript / tsc	前端类型检查
Docker Compose	本地中间件与沙箱环境编排
Python 脚本入口	统一的跨平台工程入口脚本，覆盖测试、种子导入、服务启动、契约导出与门禁执行

表 6 开发工具

（四）人工智能（AI）工具使用情况

本作品在开发过程中使用了 AI 编程辅助工具，具体如下：

AI 工具	使用方式	使用范围
Claude Code / Codex 类 AI 编程助手	以对话方式辅助生成代码骨架、编写单元测试、重构重复逻辑、排查运行报错、撰写文档与注释	作为开发提效工具贯穿全程；所有生成结果均经小组成员人工审阅、修改与测试验证后才并入代码库
大语言模型（LLM）服务	平台运行期作为“被评测目标”与“判定角色”使用，通过统一的网关接入并支持多角色路由	属于被评测对象与系统组件，不参与本作品的代码生成

表 7 AI 工具使用情况

关于 AI 工具使用的说明：小组严格遵守各赛事的原创性要求，AI 工具仅作为编写效率的辅助手段。平台的架构设计、攻击矩阵分类、三级裁判流水线、评分模型、修复手册与全部内容资产，均由小组成员基于调研与讨论自主设计；对 AI 生成的每一段代码，小组均执行了单元测试与人工复核，确保其正确性与可维护性，并对最终代码质量负责。作品的核心创意与业务逻辑不存在抄袭。

（五）开源代码来源与许可

本作品基于开源生态构建，所使用的开源组件及其许可协议如下表所示。小组严格遵循各开源协议的署名与许可要求，未使用任何闭源商业组件。

组件	版本	许可协议	用途
FastAPI	0.115+	MIT	后端 Web 框架与接口契约生成
Uvicorn	0.32+	BSD-3-Clause	ASGI 服务器
Pydantic / pydantic-settings	2.9+	MIT	数据校验与配置模型
SQLAlchemy	2.0.36+	MIT	异步 ORM 与数据访问
Alembic	1.13+	MIT	数据库迁移
Celery	5.4+	BSD-3-Clause	异步任务与定时调度
Redis (redis-py)	5.1+	MIT	限流、熔断与事件总线客户端
clickhouse-connect	0.8+	Apache-2.0	分析库客户端
qdrant-client	1.12+	Apache-2.0	向量检索客户端
minio	7.2+	AGPL-3.0	对象存储客户端
LiteLLM	1.48+	MIT	多模型统一网关
HTTPX	0.27+	BSD-3-Clause	异步 HTTP 客户端
Jinja2	3.1+	BSD-3-Clause	报告模板渲染
PyYAML	6.0+	MIT	内容资产（用例 / 规则 / 策略）加载
cryptography	43.0+	Apache-2.0 / BSD-3-Clause	凭据加密存储
Typer / Rich	0.12+ / 13.9+	MIT	命令行工具与终端输出
dnspython	2.7+	ISC	归属校验的 DNS TXT 查询
React / React DOM	19.x	MIT	前端 UI 框架
React Router	6.x	MIT	前端路由
TanStack Query	5.x	MIT	服务端状态与数据缓存
Zustand	5.x	MIT	客户端状态管理
Vite	5.4	MIT	前端构建与开发服务器
TypeScript	5.9	Apache-2.0	前端类型系统
Tailwind CSS	3.4	MIT	原子化样式
ECharts	5.5	Apache-2.0	评分与覆盖率可视化图表

Dexie	4.x	Apache-2.0	浏览器端本地草稿与离线回放
framer-motion	11.18.2	MIT	界面动效与登录页视差
ogl	1.0.x	Unlicense	背景动效的 WebGL 渲染
three.js / postprocessing	0.170 / 6.36+	MIT / Zlib	攻击矩阵页网格扫描背景
ReactBits (react-bits) 背景组件	main 分支 快照	MIT	背景动效组件源码参考与移植
Vitest / Playwright / Storybook	2.1 / 1.48+ / 8.4+	MIT	前端测试与组件走查

表 8 开源组件来源与许可

开源许可合规说明

- ① MIT / BSD-3-Clause / ISC / Apache-2.0 / Zlib / Unlicense 类协议：允许自由使用、修改与分发，本作品在文档中保留原始版权与许可声明，并在源码目录中保留各组件自带的 LICENSE 文件。
- ② AGPL-3.0 类协议（MinIO 客户端、MinIO 服务端）：本作品仅将其作为对象存储的访问客户端与配套服务使用，未修改其源码，也未将其代码并入本作品源码，因此不触发 AGPL 的衍生作品传染条款。在正式对外发布的服务化部署中，小组将进一步评估替代方案（如改用 Apache-2.0 许可的 S3 兼容组件）以彻底规避许可风险。
- ③ ReactBits 背景组件：上游仓库采用 MIT 许可，本作品在移植时完成了 TypeScript 化、设计令牌绑定与降级链封装，并按上游要求保留版权与许可声明；每个组件的来源、许可、依赖与改动点已逐项登记在项目文档中，可按上游仓库地址随时取回原文比对。
- ④ 原创部分：平台的架构设计、攻击矩阵分类体系、三级裁判流水线、SecScore 评分模型、修复手册内容、全部 YAML 内容资产，以及界面视觉设计，均为本小组原创成果。

（六）测试账号（评审演示用）

评审时可在登录界面直接使用以下演示账号体验平台。登录界面已预填账号与密码，无需手动输入。

项目	内容
访问方式	启动后端与前端服务后，浏览器访问前端地址（默认

	http://127.0.0.1:5173)
演示账号	demo@xian.local
演示密码	xian-dev
可选角色	红军 (red)、蓝军 (blue)、管理员 (admin)、分析师 (analyst)
数据租户	00000000-0000-0000-0000-000000000001 (演示租户)
账号说明	本平台当前处于开发演示态，登录环节不校验密码，任意非空密码均可登录；演练角色由登录界面上的角色选择器直接指定，所填账号仅用于标识本次演练的操作者身份。正式部署时该入口将替换为对接企业统一身份认证 (OIDC / LDAP)。

表 9 评审演示账号

若演示环境为完全离线状态、后端服务未能启动，前端会自动进入演示模式并写入本地上下文，此时仍可浏览全部页面与交互流程，但不会产生真实的演练数据。

七、操作说明

本章说明平台的环境准备、启动方式与主要功能的操作步骤。为便于评审与教学环境部署，平台提供统一的跨平台工程入口脚本，以下命令在 Windows PowerShell、Linux 与 macOS 下均可直接执行。

（一）环境准备

第一步，确认本机已安装 Python 3.12 及以上版本、Node.js 20.19 及以上版本与 pnpm 9 及以上版本。

第二步，在仓库根目录安装前端依赖：

```
cd frontend && pnpm install
```

第三步（可选），如需使用完整存储能力，启动数据面中间件：

```
docker compose -f deploy/docker/compose.dev.yml --profile data up -d
```

此步骤完全可选。未启动中间件时，平台会自动降级为 SQLite、进程内事件队列与本地文件存储，全部功能仍可正常演示，这也是小组推荐的评审演示方式。

（二）Android 客户端（APK）安装与配置

除浏览器访问外，本作品还提供 Android 安装包，供移动端评审与演示使用。该安装包为 WebView 容器形式：前端静态资源已完整打包进安装包，安装后无需联网即可打开界面；后端服务地址在应用内配置。

步骤	操作	说明
1	安装 APK	将 XIAN-v1.0-debug.apk 传输至手机并点击安装；首次安装需在系统设置中允许「安装未知来源应用」
2	打开应用	桌面图标为 XIAN，启动后直接进入登录界面
3	配置后端	点击登录页底部「服务器设置」，填写后端地址（例如 <code>http://192.168.1.5:8000</code> ），点击「测试连接」确认可达后保存
4	登录使用	使用演示账号登录，后续操作与浏览器端完全一致
5	后端放通	后端需以 <code>--host 0.0.0.0</code> 启动，且手机与后端主机处于同一局域网

表 10 Android 客户端安装与配置

关于安装包的说明：其一，安装包内的前端与浏览器端为同一份构建产物，功能与交互完全一致，不存在两套实现；其二，后端地址保存在手机本地，更换网络或后端地址时只需重新填写，无需重新安装；其三，安装包为开发调试签名，仅用于评审与内部演示，正式对外分发前需替换为正式签名并配置 HTTPS 后端；其四，若尚未配置后端地址，应用仍可打开并浏览全部界面，此时进入演示模式，不产生真实演练数据。

构建方式（供复现）：在 `frontend` 目录执行 `pnpm --filter @xian/web build` 生成前端产物，再进入 `apps/web/android` 目录执行 `gradlew assembleDebug`，产物位于 `app/build/outputs/apk/debug/`。Android 工程由 Capacitor 生成，应用标识为 `com.xian.redblue`。

（三）启动服务

步骤	操作	说明
1	python scripts/xian.py seed	导入种子内容资产：14 类攻击用例、场景模板、攻击矩阵、十关教案与修复手册
2	python scripts/xian.py api	启动后端服务，监听 127.0.0.1:8000；交互式接口文档位于 /docs
3	python scripts/xian.py web	启动前端开发服务器，监听 127.0.0.1:5173
4	浏览器访问前端地址	打开登录界面，使用演示账号登录
5	python scripts/xian.py smoke	（可选）一键自检：单元测试 → 种子导入 → 命令行 → 接口冒烟 → 前端检查 → 门禁

表 11 启动步骤

执行 `python scripts/xian.py` 不带参数可打印全部可用子命令及其说明。

（四）模式一操作流程：系统自动攻击

第 1 步：接入被测 Agent

登录后进入“Agent 资产”页面，点击新建，填写 Agent 名称并选择接入方式（HTTP 端点 / SDK / 容器镜像），填入端点地址后保存。保存成功后可在列表中看到该 Agent，状态为“待校验”。

第 2 步：完成归属校验

在 Agent 详情页点击“归属校验”，选择校验方式：DNS TXT 方式需在目标域名下添加指定内容的 TXT 记录；镜像摘要方式需提供镜像摘要进行比对。校验通过后 Agent 状态变为“已校验”。

注意：未完成归属校验的 Agent 无法作为模式一的攻击目标，创建战役时会被拒绝并提示原因。这是平台的强制授权约束，用于确保演练仅针对自有资产执行。

第 3 步：连通性与侦察

点击“连通性探测”确认目标可达；随后点击“执行侦察”，平台会发起一组无害探测，识别目标的工具集合、拒答边界与模型指纹，并生成目标画像。侦察结果将影响后续策略的自动选择。

第 4 步：创建并执行战役

进入“战役”页面点击新建，按三步向导配置：① 选择目标 Agent 与场景；② 勾选攻击范围（可按 14 类矩阵勾选）；③ 设置预算上限与并发度。保存后点击“执行”。

执行过程中，战役详情页会实时展示攻击进度：当前所处阶段、正在执行的策略、已产生的发现数量、预算消耗比例。平台在预算达到阈值时自动熔断，在连续失败时自动轮换攻击手法，在无新进展时自动收敛结束，均会在事件流中给出说明。

第 5 步：查看判定与报告

战役结束后进入“报告中心”查看结果。报告包含九个章节：执行摘要、目标与范围、方法与矩阵、发现与证据、风险评级、根因分析、修复建议、复测验证、合规映射。每条发现都可以下钻查看触发它的原始 trace 与裁判流水，确认判定依据。报告支持导出 HTML、PDF 与 JSON 三种格式。

第 6 步：应用修复并复测

在报告的“修复建议”章节中，每条发现都附有根因定位与可执行的修复产物（提示词改写差异、防护规则或代码片段）。在目标 Agent 上应用修复后，回到该条发现点击“复测”，平台会重新执行同一条攻击并展示修复前后的判定结果与分数变化，据此判断修复是否真正生效。

（五）模式二操作流程：手动攻击沙盘

第 1 步：进入关卡地图

登录时选择“红军”角色，进入“关卡”页面，可以看到十关递进的关卡地图及其通关状态。

第 2 步：开始挑战与使用提示

点击某一关进入攻击控制台。初始能量为 100 点。若对攻击思路没有头绪，可使用提示系统：三级提示分别消耗 10、20、40 点能量，提示越具体消耗越高。使用提示会记录在本次挑战的评分中。

第 3 步：提交攻击并查看结果

在控制台输入攻击载荷并提交，平台使用与模式一完全相同的三级裁判引擎对结果进行判定，并即时反馈是否通关以及判定依据。每关的通关条件不同，涵盖提示注入成功、触发越权工具调用、诱导数据外泄等不同目标。

第 4 步：攻守互换与加固

通关后可进入“攻守互换”模式，从攻击者视角切换到防守者视角，针对刚刚被攻破的环节选择加固措施。平台提供八项一键加固选项，每项均与修复手册中的具体根因一一对应，应用后返回该关重新挑战，可直观看到攻击是否被成功阻断。

第 5 步：查看成就与进度

在“个人中心”可以查看已获得的徽章、各关得分、能力雷达图与总进度，用于跟踪自身安全能力的成长轨迹。

（六）CI 回归门禁的使用

平台提供命令行门禁接口，可在持续集成流程中自动执行安全检查：

```
python scripts/xian.py scan
```

该命令会执行评测并与上一版本的评分比对。当分数跌幅超过设定阈值，或出现新的高危发现时，命令返回非零退出码，从而使持续集成流水线阻断本次合并；同时支持输出 SARIF 格式结果，可直接对接代码托管平台的代码扫描面板。

（七）常见问题

现象	原因与处理
启动时提示数据库连接失败	属正常降级行为。未配置数据库时平台自动改用 SQLite 本地文件，功能不受影响；如需使用 PostgreSQL，请配置连接串后重启。
登录时提示“已进入演示模式”	说明后端服务未启动或不可达。前端会自动写入本地上下文以支持界面演示；请确认后端已在 127.0.0.1:8000 启动。
创建战役时返回 403 拒	目标 Agent 尚未完成归属校验。请先在 Agent 详情页完成 DNS

绝	TXT 或镜像摘要校验。
战役执行后没有产生发现	属正常结果，说明被测 Agent 在该批载荷下未表现出风险。可在战役详情页查看判定流水，确认每条用例的实际判定依据。
报告导出 PDF 失败	PDF 导出依赖无头浏览器渲染，未安装时请改用 HTML 或 JSON 格式导出。

表 12 常见问题与处理

八、致谢

本项目从选题、调研到设计实现，历时数周，得到了许多帮助，在此致以诚挚谢意。

感谢指导教师在本项目选题方向、攻击矩阵分类体系与判定模型设计上给予的悉心指导，特别是在三级裁判流水线的分层思路提出的关键建议，使平台在“零漏报”与“成本可控”之间找到了合理的平衡点。

感谢学院与实验室为本项目提供的开发环境与测试设备支持，感谢参与需求调研的安全从业者与研发工程师，他们从真实业务场景出发提出的意见，在很大程度上决定了本平台目标用户与功能边界的设定。

感谢开源社区。本作品构建在 FastAPI、SQLAlchemy、Celery、React、Vite、Tailwind CSS、ECharts 等众多优秀开源项目之上，也参考了 ReactBits 的组件实现思路。正是这些开放共享的成果，让一个学生团队能够在有限时间内把精力集中在真正的业务问题上。

最后，感谢全体小组成员的投入与协作，也感谢大赛组委会提供这次宝贵的交流与学习机会。